

****Supervision of Notification of Breach of Personal Data Security****

Date: 31-08-2023

Decision

Private Companies

No Criticism

Supervision / Self-initiated Case

Unintentional Disclosure

Notification of Breach of Personal Data Security

The Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of personal data security. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-41-0135

Jyske Bank A/S (hereinafter Jyske Bank) was among the companies that the Data Protection Agency selected for supervision in the autumn of 2021 under the General Data Protection Regulation[1] and the Data Protection Act[2].

The Data Protection Agency's supervision was a written inspection that focused on whether Jyske Bank reports and documents breaches of personal data security in accordance with Article 33, paragraph 1, and Article 33, paragraph 5 of the General Data Protection Regulation, including the bank's processes for handling and recording breaches of personal data security. The supervision was based on an assessment of samples among unreported breaches as well as information about guidelines, procedures, and training activities, etc.

The supervision was announced to Jyske Bank by letter dated November 24, 2021, and the bank was simultaneously requested to answer a number of questions. The Data Protection Agency informed about the background for the supervision, noting that a review of the agency's cases regarding notifications of breaches of personal data security revealed that Jyske Bank had reported significantly fewer breaches of personal data security per employee in the financial institution than other financial institutions.

By letter dated January 6, 2022, Jyske Bank sent a statement in which the bank responded to the Data Protection Agency's questions. The bank's response was also accompanied by process descriptions and guidelines that the bank uses to comply with Article 33 of the General Data Protection Regulation.

****Summary****

In the summer and autumn of 2021, the Data Protection Agency initiated written inspections of the handling of breaches of personal data security by eight larger municipalities and eight larger banks. The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the respective municipality's population and the number of employees in the bank.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of personal data security to the Data Protection Agency within 72 hours, and they must internally document all breaches of personal data security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is broadly that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

****Group with the Most Reported Breaches****

For the group with the most reported breaches, the inspections focused, among other things, on whether the municipalities and banks had taken appropriate security measures to reduce the number of breaches of personal data security, where there had been unauthorized disclosure of personal data in connection with sending information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons. The data controller must, in this regard, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to sending personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency found on the basis of the present material that all data controllers had taken appropriate security measures. In its assessment, the Data Protection Agency emphasized that: Procedures, etc. had been developed and activities had been carried out to educate employees in data protection, including to ensure they are aware that there is no unintentional disclosure of personal data to an incorrect recipient.

They have considered and continuously implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches.

There is a strong focus on avoiding unintentional disclosure of confidential information, which both
Supported by means of business processes, ongoing guidance, etc., and systematic measures, etc.

The group with the fewest reported breaches

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's view that compliance with the rules that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are adequately familiar with internal procedures for handling breaches of personal data security, and that relevant employees can identify, handle, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented appropriate training activities that can support compliance with the requirements in the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including, among other things, the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity, as part of the inspection, to specifically assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with. Therefore, data controllers should document their justifications for all significant decisions made as a result of the breach. This is particularly relevant if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes

that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in two cases****

As mentioned, criticism has been expressed in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified during the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the registered security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to gain an overview of which breaches typically occur in the organization, and based on this, to consider whether, from a risk assessment perspective, there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It is also evident from the received consultation responses that several data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds reason to conclude that Jyske Bank has, overall, adopted appropriate procedures and guidelines and has implemented appropriate training activities to correctly capture and handle breaches of personal data security, cf. Article 33 of the General Data Protection Regulation.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's decision****

****2.1. Relevant legal provisions****

A breach of personal data security is defined in Article 4, No. 12 of the General Data Protection Regulation as a breach of security that leads to accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed.

It follows from Article 33, paragraph 1 of the General Data Protection Regulation that in the event of a breach of personal data security, the data controller must without undue delay and, where possible, no later than 72 hours after the data controller becomes aware of the breach of...

****Personal Data Security, Reporting to the Supervisory Authority****

The data controller must report any personal data breach to the supervisory authority competent in accordance with Article 55 (Data Protection Authority), unless it is unlikely that the breach poses a risk to the rights or freedoms of natural persons. If the report to the supervisory authority is not made within 72 hours, it must be accompanied by a justification for the delay.

It is the opinion of the Data Protection Authority that the requirement in Article 33 for breaches of personal data security to be reported to the Data Protection Authority within 72 hours implies that the data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly. In this regard, the data controller must ensure that all employees in the organization are adequately familiar with internal procedures for handling breaches of personal data security, and that relevant employees can identify, manage, and assess breaches of personal data security.

Furthermore, it follows from Article 33, paragraph 5 of the General Data Protection Regulation that the

data controller must document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken. This documentation must enable the supervisory authority (Data Protection Authority) to verify that the provision has been complied with.

In the Data Protection Authority's guidance from February 2018 on handling breaches of personal data security, it is stated on page 27 that the requirements for documentation can be outlined as follows:

1. Date and time of the breach.
2. What happened in connection with the breach?
3. What is the cause of the breach?
4. What (types of) personal data are covered by the breach?
5. What are the consequences of the breach for the affected individuals?
6. What remedial measures have been taken?
7. Whether – and if so, how – a report has been made to the Data Protection Authority? Why/why not?

The data controller should thus document its justifications for all significant decisions made as a result of the breach. This is particularly important if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****2.2. Assessment of Unreported Breaches****

Jyske Bank has, at the request of the Data Protection Authority, accounted for the first three breaches of personal data security that occurred in 2021, which the financial institution failed to report to the Data Protection Authority.

The first incident involved an advisor mistakenly sending a document containing personal data in the form of name, address, as well as information about gross income and any tax deductions (information for use in the annual tax assessment) regarding one customer and the names of two other customers to 10 other customers. Jyske Bank subsequently found that the registered individual had a protected address, but upon contacting the registered individual, it was stated that the reason for the address protection was solely related to the registered individual's job. The unauthorized disclosure did not raise any concerns for the registered individual. In assessing the incident, the bank emphasized the nature and scope of the information and what was communicated by the registered individual.

The second incident involved an advisor mistakenly sending an email regarding a customer's debt collection case, including CPR number, name, contact information, financial information, and a court ruling concerning a defaulted lease agreement to another lawyer than the customer's. Immediately thereafter, the bank contacted the recipient, who confirmed that the email, which had not been read, was deleted. In assessing the incident, the bank emphasized the nature and scope of the information as well as the lawyer's statutory duty of confidentiality.

The third incident involved the bank sending an amortization letter for the loan on the registered individual's rental property to another customer than the registered individual. The breach occurred because there was a historical connection that had not been deleted between the registered individual and the recipient, allowing the latter to unlawfully access information about the registered individual in the form of name and an overview of financial conditions regarding a rental property. In assessing the incident, the bank emphasized the nature and scope of the information and that the information was publicly available on tinglysning.dk.

The Data Protection Authority finds no basis to override Jyske Bank's assessment that the three incidents can be characterized as breaches of personal data security, according to Article 4, no. 12 of the data protection regulation, but that these are not subject to the obligation to report.

Thus, the Data Protection Authority finds no basis to override the assessment that it must be deemed unlikely that the respective breaches pose a risk to the rights and freedoms of natural persons, according to Article 33, paragraph 1. In relation to the first incident, the Data Protection Authority has

particularly emphasized the information obtained from the registered individual regarding the unauthorized disclosure of the information (information about financial conditions and the individual's address, which was subject to address protection) not raising any concerns for the individual.

****2.3. Documentation, Procedures, and Employee Training****

Jyske Bank has stated in the bank's statement of January 6, 2022, that since May 25, 2018, and up to the...

31. December 2021, a total of 593 breaches of personal data security have been identified in the Jyske Bank Group, of which 401 breaches occurred in Jyske Bank.

Furthermore, it appears from the statement dated January 6, 2021, and the attached documents, that Jyske Bank has, among other things, established procedures for where and how breaches of personal data security should be reported internally within the organization, whom employees can contact with questions about breaches, who is responsible for receiving, handling, and assessing breaches, as well as for reporting to the Data Protection Authority. It is also noted that internal documentation of breaches is carried out, including the justification for such if the breaches are not reported to the Data Protection Authority.

Additionally, it is stated that Jyske Bank has prepared guidelines and conducted a number of activities to educate employees on data protection, including with the aim of enabling them to identify and manage any breaches of personal data security. Jyske Bank has also explained the criteria that are included in the municipality's assessment of whether a breach of personal data security should be reported to the Data Protection Authority.

Based on the submitted material, including information about the unreported breaches from 2021, the Data Protection Authority's immediate assessment is that Jyske Bank has overall adopted appropriate procedures and guidelines, etc., and has conducted appropriate training activities that can support compliance with the requirements of Article 33 of the General Data Protection Regulation, and which can thereby ensure that breaches of personal data security are captured within the organization, so that they can be assessed as to whether the breach should be reported to the Data Protection Authority, as well as allowing for documentation of the breaches, including the justification for them if they are not reported to the Data Protection Authority.

It is noted that the Data Protection Authority has not had the opportunity, as part of its supervision, to specifically assess whether all relevant employees have completed the relevant training activities, and that the authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)